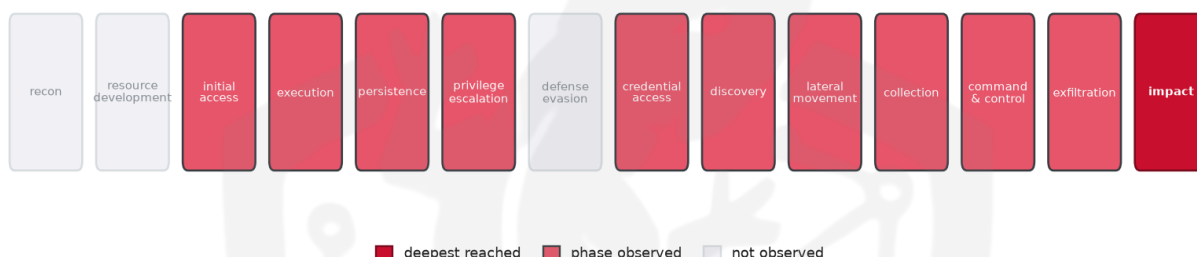


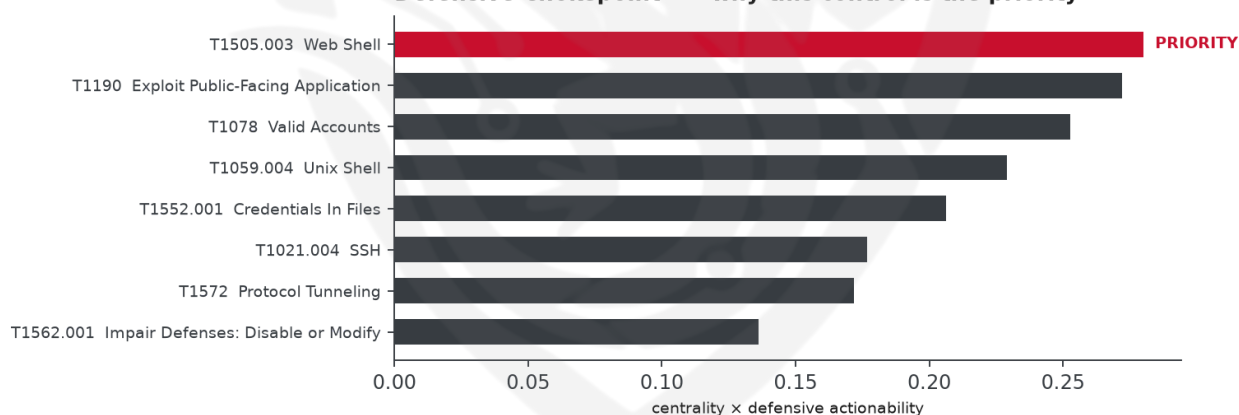
THREAT REPORT: CISCO SECURE FIREWALL MANAGEMENT CENTER EXPLOITATION BY UAT-12197, UAT-11823, UAT-11988 AND SANDWORM

Visual Summary

Kill-Chain Reach — Critical (deepest phase reached: impact)



Defensive Chokepoint — why this control is the priority



The control that most disrupts the attack (priority in crimson).

Summary

The source attributes this activity to UAT-12197, UAT-11823, UAT-11988 and Sandworm. The actors are actively exploiting CVE-2026-20316 in Cisco Secure Firewall Management Center and have deployed the Cyclops Blink – S0687 and Qilin malware families. Victim geography and sectors are not disclosed in the source. Priority should be given to integrity-monitoring web-server directories for web shells, restricting server module/plugin installation, and promptly patching CVE-2026-20316 on all affected systems.

Threat Overview

UAT-12197, UAT-11823, UAT-11988 and Sandworm are leveraging the Cyclops Blink – S0687 and Qilin malware families to exploit the public-facing vulnerability CVE-2026-20316 (also referencing

CVE-2026-20079) in Cisco Secure Firewall Management Center. The campaign's victimology is listed as data insufficient, with no specific countries or sectors identified.

Attack Chain and Priority Control

The observed activity follows a typical multi-stage chain:

1. **Exploit Public-Facing Application (T1190)** – exploitation of CVE-2026-20316 in the Cisco management interface.
2. **Web Shell Deployment (T1505.003)** – installation of a web shell to maintain persistent access.
3. **Valid Accounts (T1078) / Domain Account (T1087.002) / Domain Groups (T1069.002)** – creation and use of legitimate-looking accounts.
4. **Credential Dumping (T1003) & Credentials In Files (T1552.001)** – harvesting OS and domain credentials.
5. **Remote System Discovery (T1018) & File and Directory Discovery (T1083)** – mapping the internal network and locating valuable data.
6. **Protocol Tunneling (T1572) & Internal Proxy (T1090.001)** – covert channel establishment for command-and-control.
7. **Data Encrypted for Impact (T1486)** – encrypting exfiltrated data before exfiltration.
8. **Exfiltration to Cloud Storage (T1567.002)** – moving stolen data to cloud repositories.

Priority technique: T1505.003 Web Shell

Priority control (as stated in the source): *Integrity-monitor web-server directories for web shells; restrict server module/plugin installation. In parallel, patch CVE-2026-20316 on all affected systems.*

Infrastructure and Corroboration

Third-party enrichment indicates that the malicious infrastructure is hosted by Shock Hosting LLC. AbuseIPDB reports no high-confidence malicious indicators associated with the observed IPs, and abuse.ch does not corroborate any additional malware families.

Technical Appendix

Ground-truth telemetry from the source pulse; analytical scores are secondary and clearly labelled.

Observed Techniques (ATT&CK, expert-tagged by source)

- T1560.001 Archive via Utility
- T1003 OS Credential Dumping
- T1059.007 JavaScript
- T1071.004 DNS
- T1087.002 Domain Account
- T1069.002 Domain Groups
- T1021.004 SSH
- T1190 Exploit Public-Facing Application

- T1572 Protocol Tunneling
- T1505.003 Web Shell
- T1083 File and Directory Discovery
- T1552.001 Credentials In Files
- T1059.004 Unix Shell
- T1562.001 Impair Defenses: Disable or Modify Tools
- T1078 Valid Accounts
- T1486 Data Encrypted for Impact
- T1567.002 Exfiltration to Cloud Storage
- T1071.001 Web Protocols
- T1136 Create Account
- T1018 Remote System Discovery
- T1090.001 Internal Proxy

Analytical Scores

- Priority technique (graph chokepoint): T1505.003 Web Shell (centrality 0.2949).
- Operational risk: Critical (score 1.0, reaches impact).

Behavioral Signature Cluster

- Method: technique-overlap cosine vs 170 MITRE ATT&CK Groups (top overlap 0.4721; reference threshold $\tau = 0.6$).
- These are behavioural resemblances for defensive playbook cross-referencing, not an identity assessment. Where the source pulse names an actor, that attribution is authoritative; the overlaps below neither confirm nor contest it.

Nearest historical profiles by behavioural overlap (resemblance only):

Historical Profile	Behavioural Overlap
Fox Kitten	0.4721
FIN13	0.4638
ToddyCat	0.4146
Scattered Spider	0.4008
Ember Bear	0.3974

Enrichment Signal

- Highest AbuseIPDB confidence among IOCs: 0%.

Indicators of Compromise (defanged — non-clickable)

The network and file indicators observed in this activity are listed below for blocklisting:

Type	Indicator	Context
IP	208[.]123[.]119[.]215	AbuseIPDB 0% (US) · AS395092 Shock Hosting LLC
IP	91[.]214[.]78[.]118	AbuseIPDB 0% (NL)
Hash	6f98add5d1a7729192b6ad8491d85c505c64836f7881742d6b93bd8e3d2fe461	
Hash	b037f45e02a289325a1a5eb0d4db6a9fce9954fd0fd07162cb4eb2acbef77d	
Hash	db491181ece3f319de6567ab6f6daa90c6879911cd890155e6b7d8cc7a1a8c8e	

Reputation by AbuseIPDB · malware attribution by abuse.ch · Geo/ASN data by IP2Location LITE.

Flame Cell // Adversary Pivot [BETA]

BETA. A hypothetical tabletop projection, anchored to documented ATT&CK behaviour and technique co-occurrence across 170 tracked groups. It is not a prediction; treat it as a war-game prompt and review before acting. Spot a pivot that looks wrong? norbert@salacti.com

- **Control applied:** T1505.003 Web Shell (persistence)
- **Observed here:** T1505.003 Web Shell was the persistence control point here; the pivot is drawn from UAT-12197, UAT-11823, UAT-11988, Sandworm's own documented ATT&CK repertoire.
- **Projected pivot:** T1053 Scheduled Task/Job (persistence)
- **Basis:** documented in Sandworm's own ATT&CK repertoire, and disproportionately paired with Web Shell across tracked groups (lift 1.6, ~1.6x base rate). Their move, not a generic one.

With T1505.003 Web Shell blocked, UAT-12197, UAT-11823, UAT-11988, Sandworm could preserve the same objective by pivoting to T1053 Scheduled Task/Job, a technique from Sandworm's documented repertoire. Defensive countermeasure: Alert on new scheduled tasks (Event ID 4698); restrict schtasks/at to admins; baseline legitimate task creators.

Also plausible (same tactic): T1133 External Remote Services (n=13, lift 2.5)

Detection and hardening for the pivot (T1053 Scheduled Task/Job)

- **Telemetry:** Windows Security (Object Access audit); Microsoft-Windows-TaskScheduler/Operational; Sysmon
- **Detect:**
 - Security 4698 (task created), 4702 (updated), 4700/4701 (enabled/disabled), 4699 (deleted)
 - TaskScheduler/Operational 106 (registered), 140 (updated), 141 (deleted)
 - Sysmon 1 for schtasks.exe and at.exe; Sysmon 11 for writes under C:\Windows\System32\Tasks\
- **Harden:**

- Restrict schtasks/at to administrators; disable the legacy at.exe
- Baseline the legitimate task creators and alert on anything outside it
- **MITRE:** M1047 Audit, M1028 Operating System Configuration, M1026 Privileged Account Management · DS0003 Scheduled Job, DS0009 Process, DS0022 File

